

INTERNAL SECURITY AUDIT REPORT

KifaruCart Global Ltd.

Cross-Border E-commerce and Logistics Security Assessment

Table 1. Document Control

Attribute	Details
Organization	KifaruCart Global Ltd.
Assessment Date	August, 2026
Prepared By	Lead Cybersecurity Auditor
Target Audience	Executive Leadership, IT Leadership, Operations Management
Document Version	1.0 (Refined Assessment)
Classification	Confidential / Internal Security Report

TABLE OF CONTENTS

MEMORANDUM4

1. AUDIT SCOPE AND OBJECTIVES4

 1.1 Scope Definition4

 1.2 Primary Audit Objectives5

2. ASSET INVENTORY AND DATA CLASSIFICATION.....5

 2.1 Information Asset Mapping5

 2.2 Data Classification Matrix6

3. TECHNICAL AND ADMINISTRATIVE CONTROLS EVALUATION7

4. REGULATORY AND COMPLIANCE GAP ANALYSIS.....7

 4.1 Kenya Data Protection Act (ODPC).....7

 4.2 Delaware Personal Data Privacy Act (DPDPA).....8

 4.3 Payment Card Industry Data Security Standard (PCI DSS)8

5. NIST CYBERSECURITY FRAMEWORK (CSF) 2.0 ALIGNMENT8

6. RISK REGISTER9

7. KEY FINDINGS AND DETAILED RECOMMENDATIONS9

 7.1 Finding 1: Absence of Enforced Multi-Factor Authentication (R-001).....9

 7.2 Finding 2: Overly Broad Access Permissions to Customer PII (R-002).....9

 7.3 Finding 3: Lack of Logging for Administrative Status Modifications (R-006)10

 7.4 Finding 4: Absence of Incident Response and Recovery Policies (R-005, R-007)10

8. REMEDIATION ROADMAP10

LIST OF TABLES

Table 1. Document Control.....1

Table 2. Audit Scope and Boundaries.....4

Table 3. Information Asset Mapping.....5

Table 4. Data Classification Matrix.....6

Table 5. Technical and Administrative Controls Evaluation.....7

Table 6. NIST CSF 2.0 Alignment.....8

Table 7. Risk Register9

Table 8. Remediation Roadmap.....10

TABLE OF FIGURES

No figures are included in this report. The report contains labeled tables only.

MEMORANDUM

TO: Senior Management and IT Leadership

FROM: Lead Cybersecurity Auditor

DATE: August 22, 2026

SUBJECT: Internal Security Audit Findings and Strategic Roadmap

An internal security audit was conducted to evaluate the security program, compliance readiness, and risk posture of KifaruCart Global Ltd. across its e-commerce and logistics infrastructure in Kenya and the United States.

The company handles customer identities, residential addresses, financial receipts, customs documentation, and employee records. The overall risk score assigned to KifaruCart is 8/10 (High) due to significant gaps in access control, administrative logging, threat detection, disaster recovery testing, and privacy governance.

Baseline technical controls are active, including HTTPS encryption, perimeter firewalls, weekly backups, and facility access controls. However, critical vulnerabilities leave the platform exposed to account takeover, payment fraud, unauthorized record modification, and regulatory non-compliance. Immediate implementation of the remediation roadmap outlined in Section 8 is recommended.

1. AUDIT SCOPE AND OBJECTIVES

1.1 Scope Definition

The audit scope encompassed the entirety of KifaruCart's digital infrastructure, administrative endpoints, cloud services, storage repositories, backup processes, and physical warehouse security controls.

Table 2. Audit Scope and Boundaries

System / Asset Name	Scope Status	Functional Notes & Boundaries
Customer Portal	In Scope	E-commerce web platform for account registration, order placement, and delivery tracking.
Admin Portal	In Scope	Internal operational portal for order, refund, payment, and logistics administration.
Warehouse Management System (WMS)	In Scope	Package intake, processing, tracking, and weight verification in Kenya and U.S. facilities.
Customer Database	In Scope	Master database storing customer profiles, address histories, and contact information.
Payment Records Storage	In Scope	Repositories housing invoices, receipts, payment confirmations, and transaction references.
Google Workspace / Microsoft 365	In Scope	Primary staff communication, file creation, document sharing, and corporate email channels.
Cloud Storage Repositories	In Scope	Storage holding vendor agreements, customs clearing documents, and internal operational reports.
Staff Workstations	In Scope	Endpoints used by customer support, finance, administration, and warehouse staff.
Office & Warehouse Networks	In Scope	Internal wired and wireless networks serving corporate endpoints and warehouse scanning devices.
Data Backup Infrastructure	In Scope	Weekly backup mechanisms evaluated for availability and disaster recovery readiness.
Physical Facilities	Limited Scope	High-level review of physical access locks, CCTV surveillance, visitor logs, and package security.
External Seller Platforms	Out of Scope	Excluded third-party marketplace platforms such as Amazon, eBay, and

System / Asset Name	Scope Status	Functional Notes & Boundaries
		Walmart.
Payment Processor Backends	Out of Scope	External gateway infrastructure is excluded; only internal handling of payment references was audited.
Courier Partner Logistics	Out of Scope	Third-party courier and external shipping partner networks are excluded.

1.2 Primary Audit Objectives

- Identify and catalog critical organizational assets and sensitive data types.
- Evaluate security risks affecting Confidentiality, Integrity, and Availability (CIA Triad).
- Review technical, administrative, and physical security controls against industry-standard checklists.
- Perform a gap analysis against statutory regulations, including ODPC (Kenya), Delaware Privacy Law, and PCI DSS.
- Align organizational capabilities with the NIST Cybersecurity Framework (CSF) 2.0.
- Formulate a prioritized Risk Register and actionable remediation roadmap.

2. ASSET INVENTORY AND DATA CLASSIFICATION

2.1 Information Asset Mapping

Table 3. Information Asset Mapping

Asset Category	Asset Description & Operational Role
Customer Portal	Web platform allowing customers to register, submit item links, make payments, and track orders.
Admin Portal	Staff dashboard for managing customer accounts, order statuses, payment approvals, and shipments.
Customer Database	Storage holding customer registration data, order history, phone numbers, and physical addresses.
Warehouse System	Software tracking package arrivals, package status, package weight, customs clearance, and dispatch.
Payment Folder	Storage directories holding invoices, transaction references, receipt logs, and refund receipts.
Cloud Repositories	Storage used for customs documentation, vendor agreements, tax records, and operational reports.
Workstations & Scanners	Staff laptops and warehouse barcode scanners used to process orders and track inventory.
Network Devices & CCTV	Office firewalls, Wi-Fi routers, backup storage drives, and warehouse surveillance systems.

2.2 Data Classification Matrix

Table 4. Data Classification Matrix

Data Category	Representative Examples	Sensitivity Level	Primary CIA Risk Exposure
Customer Identity PII	Full name, email address, phone number, passport/national ID details	High	Confidentiality: Exposure risks identity theft, targeted fraud, and regulatory fines.
Delivery Information	Home residential address, pickup location, specialized delivery notes	High	Confidentiality: Exposure risks customer profiling and physical safety compromise.
Payment Data	Payment receipts, transaction references, invoice IDs, refund records	High	Integrity / Confidentiality: Manipulation risks financial loss and PCI non-compliance.
Customs Records	Import clearance paperwork, tax filings, identity records	High	Confidentiality: Breach may violate statutory cross-border customs and privacy obligations.
Staff HR Data	Employee contracts, identity cards, payroll details, emergency contacts	High	Confidentiality: Unauthorized disclosure violates employee privacy and labor protections.
Order & Vendor Info	Item links, seller contact information, declared order values	Medium	Integrity: Unauthorized changes can cause procurement and fulfillment errors.
System Audit Logs	Admin access logs, status change records, portal login attempts	Medium	Integrity: Incomplete logs prevent forensic analysis and operational auditing.

3. TECHNICAL AND ADMINISTRATIVE CONTROLS EVALUATION

The assessment revealed that while foundational technical safeguards exist, significant operational controls are missing or only partially enforced.

Table 5. Technical and Administrative Controls Evaluation

Control Category	Implementation Status	Current Audit Finding & Technical Details
Least Privilege Access	Partial	Support, finance, and warehouse personnel possess overlapping access to customer data.
Multi-Factor Authentication	Partial	MFA is enabled for IT administrators but is not enforced across general workforce accounts.
Separation of Duties	Partial	Select users can initiate, authorize, and process customer refunds independently.
Password Enforcement	Partial	Password creation is required, but password complexity, length, and rotation are not consistently enforced.
Enterprise Password Management	No	No approved password manager is used; informal credential sharing was observed.
Data Encryption	Partial	HTTPS is enforced for web traffic; laptop full-disk encryption is unverified.
Network Firewalls	Yes	Standard network firewalls and border router filtering rules are in place.
Intrusion Detection System	No	No network or host-based intrusion detection systems (IDS) or SIEM solutions are deployed.
Endpoint Antivirus	Partial	Antivirus software is present on select laptops but lacks centralized administration.
Data Backups	Yes	Database and file system backups are executed weekly.
Backup Restore Testing	No	Backup restoration procedures have never been documented or systematically tested.
Disaster Recovery Planning	No	No documented Disaster Recovery (DR) or Business Continuity Plan (BCP) exists.
Incident Response Planning	No	No formal policy exists for managing security breaches, fraud, or ransomware incidents.
Data Classification Policy	No	Enterprise data is unclassified, resulting in sensitive files residing in open shares.
Data Retention Schedule	No	Historical customer profiles and transaction records are stored indefinitely.
Vendor Risk Management	No	No formal security evaluation process exists for logistics partners or cloud vendors.
Security Awareness Training	No	Employees receive no structured security training, anti-phishing drills, or privacy guidance.
Physical Access Controls	Yes	Physical offices and warehouses use perimeter locks and access restrictions.
CCTV Surveillance	Partial	Cameras monitor the main Kenya warehouse, but coverage gaps exist in handling zones.

4. REGULATORY AND COMPLIANCE GAP ANALYSIS

4.1 Kenya Data Protection Act (ODPC)

- **Purpose Limitation & Notice:** Privacy policies exist but fail to explicitly inform customers that personal data is shared with foreign logistics partners, customs brokers, and courier vendors.
- **Cross-Border Transfers:** Personal data belonging to Kenyan citizens is transferred between Kenya and U.S. cloud infrastructure without documented safeguards or legal transfer mechanisms.

- **Data Retention Schedules:** Personal identities and delivery addresses are retained indefinitely without an established retention schedule or automated deletion mechanism.
- **Breach Notification Readiness:** The organization lacks an incident response process to support regulatory notification within required data breach reporting timelines.

4.2 Delaware Personal Data Privacy Act (DPDPA)

- **Consumer Rights Mechanisms:** No operational workflow exists to handle customer requests for data access, correction, deletion, or opt-out processing.
- **Data Minimization Practices:** Customer onboarding forms collect full government identification details before those details are required for customs clearance.

4.3 Payment Card Industry Data Security Standard (PCI DSS)

- **Storage & Access Controls:** Payment references, invoices, and payment confirmations are stored in cloud directories accessible to unapproved operational staff.
- **Workflow Authorization:** Refund workflows lack separation of duties, allowing individual staff members to initiate and issue refunds without secondary approval.
- **Transaction Monitoring:** Financial transaction logs and admin portal changes are not routinely audited for suspicious activity.

5. NIST CYBERSECURITY FRAMEWORK (CSF) 2.0 ALIGNMENT

The assessment indicates that KifaruCart's security posture is immature, with major deficiencies in the Govern, Detect, Respond, and Recover functions.

Table 6. NIST CSF 2.0 Alignment

NIST Function	Implementation Status	Audit Observation	Strategic Governance Requirement
GOVERN	Partial	Security tasks are managed informally by IT staff without formal corporate governance or written policies.	Designate formal security roles, define executive oversight, and draft organizational security policies.
IDENTIFY	Partial	Major systems are known, but detailed asset inventories, data-flow maps, and vendor lists are absent.	Establish formal asset inventories, data-flow diagrams, and a vendor risk registry.
PROTECT	Partial	HTTPS and perimeter firewalls are active, but universal MFA, drive encryption, and training are missing.	Mandate universal MFA, enforce least-privilege controls, encrypt endpoints, and deliver security training.
DETECT	Minimal	Server logs exist locally, but central logging, intrusion detection, and active monitoring are lacking.	Deploy centralized logging (SIEM), implement intrusion detection, and audit critical actions.
RESPOND	Non-Existent	No documented incident response plan exists to guide management during a security breach.	Construct an Incident Response Plan defining escalation tiers, communication protocols, and containment actions.
RECOVER	Partial	Backups are performed weekly, but restoration tests and disaster recovery plans do not exist.	Document formal Disaster Recovery procedures and execute monthly backup restoration testing.

6. RISK REGISTER

The identified organizational risks have been evaluated based on threat likelihood, potential impact, impacted CIA vector, and overall severity.

Table 7. Risk Register

Risk ID	Risk Description	Affected System	CIA Vector	Risk Severity
R-001	Multi-Factor Authentication (MFA) is not enforced across general staff accounts.	Workspace, Email, Admin Portal	Confidentiality	Critical
R-002	Customer delivery addresses and profiles are accessible to unapproved staff.	Customer DB, Support Portal	Confidentiality	Critical
R-003	Financial transaction records are stored in broadly accessible cloud directories.	Cloud Payment Repositories	Confidentiality	Critical
R-004	Single-user refund workflows lack appropriate separation of duties.	Admin & Payment Dashboard	Integrity	High
R-005	The organization lacks a documented Incident Response Plan (IRP).	Enterprise Infrastructure	CIA	High
R-006	Package status updates in the WMS occur without audit logging.	Warehouse Management System	Integrity	High
R-007	Data backup restoration procedures are not verified through testing.	Database & System Backups	Availability	High
R-008	Laptops used by operational staff lack managed full-disk encryption.	Staff Workstations	Confidentiality	High
R-009	Cross-border data transfers (Kenya to U.S.) are undocumented and unaligned with ODPC expectations.	Customer & Order Systems	Confidentiality	High
R-010	Staff members receive no formal security awareness or anti-phishing training.	Human Resources	Confidentiality	High
R-011	User offboarding workflows do not systematically revoke account permissions.	Identity Management Systems	Confidentiality	Medium
R-012	Third-party vendor cybersecurity risks are not systematically evaluated.	Logistics & Payment Vendors	Availability	Medium

7. KEY FINDINGS AND DETAILED RECOMMENDATIONS

7.1 Finding 1: Absence of Enforced Multi-Factor Authentication (R-001)

- **Observation:** MFA is implemented for IT administrators but remains optional for general employees handling sensitive customer and payment records.
- **Impact:** Attackers obtaining credentials via credential stuffing or phishing can gain unauthorized entry into corporate email, cloud storage, and administrative portals.
- **CIA Impact:** Confidentiality.
- **Severity:** Critical.
- **Remediation:** Enforce mandatory MFA across all user accounts using authenticator applications or security keys, prioritizing customer support, finance, and warehouse operations personnel.

7.2 Finding 2: Overly Broad Access Permissions to Customer PII (R-002)

- **Observation:** Customer support, finance, and warehouse teams possess overlapping access permissions to customer identity details and physical home addresses.
- **Impact:** Excessive internal access increases the likelihood of unauthorized data viewing, insider threats, and non-compliance with data protection laws.
- **CIA Impact:** Confidentiality.
- **Severity:** Critical.

- **Remediation:** Apply strict Role-Based Access Control (RBAC) and restrict customer PII access to employees requiring the data for active order fulfillment.

7.3 Finding 3: Lack of Logging for Administrative Status Modifications (R-006)

- **Observation:** Administrative users can alter package delivery statuses, weight logs, and customer account parameters without generating detailed, immutable log records.
- **Impact:** Malicious or accidental modifications to order statuses cannot be attributed to specific users, which impedes post-incident investigation.
- **CIA Impact:** Integrity.
- **Severity:** High.
- **Remediation:** Implement audit logging across the Admin Portal and Warehouse Management System to capture user IDs, timestamps, IP addresses, and specific modifications.

7.4 Finding 4: Absence of Incident Response and Recovery Policies (R-005, R-007)

- **Observation:** No documented plan exists for handling cyber incidents, and data backups are executed weekly without regular restoration verification.
- **Impact:** This creates risk of prolonged downtime during ransomware events, inability to restore corrupted databases, and failure to notify regulators within statutory timelines.
- **CIA Impact:** Confidentiality, Integrity, Availability.
- **Severity:** High.
- **Remediation:** Formulate an Incident Response Plan detailing containment protocols and communication chains, and initiate monthly backup restoration testing.

8. REMEDIATION ROADMAP

Table 8. Remediation Roadmap

Phase	Timeline	Priority Actions
Phase 1: Immediate Remediation	0-30 Days	Enforce universal MFA across Google Workspace, admin dashboard, and cloud service accounts. Apply least privilege to shared directories containing payment records, customs documents, and customer PII. Enforce separation of duties so refund creation and approval require separate authorized accounts.
Phase 2: Tactical Safeguards	30-90 Days	Deploy managed full-disk encryption and centralized antivirus across employee workstations. Enable logging for admin actions, shipment updates, and account modifications. Draft and distribute an Incident Response Plan and conduct the first backup restoration test.
Phase 3: Strategic Governance	90+ Days	Draft and enforce Data Classification, Data Retention, and Cross-Border Data Transfer Policies. Establish a vendor risk evaluation framework for third-party logistics and payment partners. Conduct mandatory quarterly cybersecurity awareness training and phishing simulations.